

AI WEB AUDITOR LAB REPORT

- Generated: 2026-09-12T03:02:28Z
- Report generator: ai-web-auditor 0.25.0
- Scan version: 0.25.0
- Scan status: completed

TARGET

Field Value

Original URL <http://127.0.0.1:55917/members/>

Normalized URL <http://127.0.0.1:55917/members/>

Host 127.0.0.1

Scheme http

Port 55917

AUDIT PROFILE

Field Value

Profile Publico

Mode Public / anonymous

Request header names none

Cookie names none

Sensitive values redacted from outputs

Notes Perfil anonimo del laboratorio.

ENGAGEMENT

Field Value

Client Practica Evolve

Auditor David

Engagement Demo v0.25.0

Scope summary <http://127.0.0.1:55917/members/>

Notes Laboratorio local controlado en localhost.

EXECUTIVE SUMMARY

The scan generated 22 finding(s): 0 critical, 3 high, 4 medium, 6 low and 9 informational.

AUDIT DASHBOARD

- Readiness: needs_attention
- Risk: HIGH (89/100)
- Coverage: 89%
- Pending items: 15
- Checklist: 14/19
- Changes: baseline_required

COVERAGE METRICS

Area	Value	Target	Status
------	-------	--------	--------

Modulos ejecutados	10	10	done
--------------------	----	----	------

URLs inventariadas 36 1 done
Puntos de entrada 36 1 done
Endpoints JavaScript 9 1 done
Reglas pasivas 13 15 done
Controles OWASP 34 1 done
Capturas visuales 3 3 done
Subdominios revisados 0 1 pending
Puertos revisados 1 1 done

DASHBOARD PRIORITIES

- HIGH HTTP Basic Authentication over HTTP
- HIGH HTTP is not redirected to HTTPS
- HIGH HTTP method TRACE is advertised
- MEDIUM HTTP method DELETE is advertised
- MEDIUM HTTP method PUT is advertised

PENDING WORK

Severity	Item	Next step
----------	------	-----------

HIGH	HTTP Basic Authentication over HTTP	Force HTTPS before authentication and enable HSTS after validation.
------	-------------------------------------	---

HIGH	HTTP is not redirected to HTTPS	Redirect all HTTP traffic to HTTPS and consider enabling HSTS after verification.
------	---------------------------------	---

HIGH	HTTP method TRACE is advertised	Disable unnecessary HTTP methods or enforce strict authorization before use.
------	---------------------------------	--

MEDIUM	Priorizar puntos de entrada	Abre la pestana Entradas y filtra login, admin, token, upload, POST o delete.
--------	-----------------------------	---

MEDIUM	Revisar modulo basic_auth	Revisa la evidencia del modulo y decide si requiere validacion manual.
--------	---------------------------	--

MEDIUM	Revisar modulo cookies	Revisa la evidencia del modulo y decide si requiere validacion manual.
--------	------------------------	--

MEDIUM	Revisar modulo crawler	Revisa la evidencia del modulo y decide si requiere validacion manual.
--------	------------------------	--

MEDIUM	Revisar modulo fingerprinting	Revisa la evidencia del modulo y decide si requiere validacion manual.
--------	-------------------------------	--

MEDIUM	Revisar modulo http	Revisa la evidencia del modulo y decide si requiere validacion manual.
--------	---------------------	--

MEDIUM	Revisar modulo http_methods	Revisa la evidencia del modulo y decide si requiere validacion manual.
--------	-----------------------------	--

MEDIUM	Revisar modulo ports	Revisa la evidencia del modulo y decide si requiere validacion manual.
--------	----------------------	--

MEDIUM	Revisar modulo security_headers	Revisa la evidencia del modulo y decide si requiere validacion manual.
--------	---------------------------------	--

AUDIT CHECKLIST

Group	Item	Status	Evidence
-------	------	--------	----------

Alcance	Scope validado	done	El objetivo entra en hosts/rutas autorizadas.
---------	----------------	------	---

Alcance	Perfil documentado	done	Perfil anonimo/autenticado incluido en JSON.
---------	--------------------	------	--

Transporte	HTTP y redirecciones revisadas	done	Estado, URL final y cadena de redireccion revisados.
------------	--------------------------------	------	--

Transporte TLS basico revisado review Certificado y datos basicos TLS si aplica.
Transporte Cabeceras defensivas revisadas done HSTS, CSP, X-Frame-Options y politicas de navegador.
Transporte Cookies revisadas done Secure, HttpOnly y SameSite.
Superficie Fingerprinting ejecutado done Tecnologias y ficheros publicos.
Superficie Crawler seguro ejecutado done Enlaces, robots, sitemap y rutas relevantes.
Superficie Inventario generado done URLs normalizadas y clasificadas.
Superficie Puntos de entrada generados done Endpoints, parametros, formularios y metodos.
Superficie JavaScript revisado done Scripts y referencias a endpoints.
Recon Subdominios considerados optional DNS seguro si el scope lo permite.
Recon Puertos considerados done TCP connect limitado si el scope lo permite.
Trazabilidad Reglas OWASP calculadas done Mapeo WSTG/ASVS.
Trazabilidad Valoracion de riesgo generada done Riesgo, prioridades, quick wins y plan.
Entregables Evidencia visual generada done Capturas SVG de resumen, fingerprint y cobertura.
Entregables Informe preparado pending Genera Markdown/HTML/PDF desde la pestana Informe.
Seguimiento Comparacion realizada pending Compara contra baseline cuando exista una segunda ejecucion.
Seguimiento Puertos abiertos revisados review Si hay puertos abiertos, documenta si pertenecen al alcance.

DASHBOARD SAFETY NOTES

- Dashboard values are derived from passive evidence already present in the audit JSON.
- Pending items are triage guidance; they are not proof of exploitability.
- No additional requests, exploitation, fuzzing, brute force or form submission are performed to build this dashboard.

SEVERITY SUMMARY

Severity Count

CRITICAL 0

HIGH 3

MEDIUM 4

LOW 6

INFO 9

RISK ASSESSMENT

- Risk level: HIGH
- Risk score: 89/100
- Priorities: 10
- Quick wins: 8

COVERAGE

Metric Value

Modules run 10

Module warnings 8

Module errors 0

URLs 36

Forms 2

Entry points 36
Entry point parameters 8
State-changing entry points 6
JavaScript endpoints 9
JavaScript scripts 3
Resolved subdomains 0
Open TCP ports 1
Passive rules matched 13
OWASP controls matched 34
Unmapped findings 0

PRIORITIES

Rank	Severity	Finding	Reason	Recommended action
------	----------	---------	--------	--------------------

- | | | | | |
|----|--------|---|--|---|
| 1 | HIGH | AUTH-BASIC-OVER-HTTP: HTTP Basic Authentication over HTTP | credentials may be exposed before transport security is enforced | Force HTTPS before authentication and enable HSTS after validation. |
| 2 | HIGH | HTTP-NO-HTTPS-REDIRECT: HTTP is not redirected to HTTPS | unencrypted HTTP remains reachable for the same service | Redirect all HTTP traffic to HTTPS and consider enabling HSTS after verification. |
| 3 | HIGH | METHOD-TRACE-ADVERTISED: HTTP method TRACE is advertised | an unnecessary HTTP method is advertised by the server | Disable unnecessary HTTP methods or enforce strict authorization before use. |
| 4 | MEDIUM | METHOD-DELETE-ADVERTISED: HTTP method DELETE is advertised | medium finding reported by the http_methods module | Disable unnecessary HTTP methods or enforce strict authorization before use. |
| 5 | MEDIUM | METHOD-PUT-ADVERTISED: HTTP method PUT is advertised | medium finding reported by the http_methods module | Disable unnecessary HTTP methods or enforce strict authorization before use. |
| 6 | MEDIUM | COOKIE-SAMESITE-NONE-WITHOUT-SECURE: Cookie uses SameSite=None without Secure | medium finding reported by the cookies module | Set Secure or avoid SameSite=None if cross-site usage is not required. |
| 7 | MEDIUM | HEADER-CONTENT_SECURITY_POLICY-MISSING: Content-Security-Policy header is missing | medium finding reported by the security_headers module | Define an appropriate Content-Security-Policy header for this application. |
| 8 | LOW | COOKIE-HTTPONLY-MISSING: Cookie missing HttpOnly flag | client-side scripts may access cookies without HttpOnly | Set HttpOnly for session or sensitive cookies. |
| 9 | LOW | COOKIE-HTTPONLY-MISSING: Cookie missing HttpOnly flag | client-side scripts may access cookies without HttpOnly | Set HttpOnly for session or sensitive cookies. |
| 10 | LOW | COOKIE-SAMESITE-MISSING: Cookie missing SameSite attribute | low finding reported by the cookies module | Set SameSite=Lax or SameSite=Strict unless cross-site usage is required. |

QUICK WINS

- HTTP is not redirected to HTTPS: Redirect all HTTP traffic to HTTPS and consider enabling HSTS after verification.
- Content-Security-Policy header is missing: Define an appropriate Content-Security-Policy header for this application.
- Clickjacking protection header is missing: Set frame-ancestors in Content-Security-Policy or use X-Frame-Options where appropriate.
- X-Content-Type-Options nosniff is missing: Set X-Content-Type-Options: nosniff.
- Referrer-Policy header is missing: Define an appropriate Referrer-Policy header for this

application.

- Cookie missing HttpOnly flag: Set HttpOnly for session or sensitive cookies.
- Cookie missing SameSite attribute: Set SameSite=Lax or SameSite=Strict unless cross-site usage is required.
- Cookie missing HttpOnly flag: Set HttpOnly for session or sensitive cookies.

REMEDIATION PLAN

IMMEDIATE

Reduce the highest observable risk first.

- HTTP Basic Authentication over HTTP: Force HTTPS before authentication and enable HSTS after validation.
- HTTP is not redirected to HTTPS: Redirect all HTTP traffic to HTTPS and consider enabling HSTS after verification.
- HTTP method TRACE is advertised: Disable unnecessary HTTP methods or enforce strict authorization before use.
- Cookie missing HttpOnly flag: Set HttpOnly for session or sensitive cookies.
- Review every open TCP port and confirm it is required for the approved scope.

SHORT TERM

Apply low-effort hardening and validation.

- HTTP method DELETE is advertised: Disable unnecessary HTTP methods or enforce strict authorization before use.
- HTTP method PUT is advertised: Disable unnecessary HTTP methods or enforce strict authorization before use.
- Cookie uses SameSite=None without Secure: Set Secure or avoid SameSite=None if cross-site usage is not required.
- Content-Security-Policy header is missing: Define an appropriate Content-Security-Policy header for this application.
- HTTP is not redirected to HTTPS: Redirect all HTTP traffic to HTTPS and consider enabling HSTS after verification.
- Clickjacking protection header is missing: Set frame-ancestors in Content-Security-Policy or use X-Frame-Options where appropriate.
- X-Content-Type-Options nosniff is missing: Set X-Content-Type-Options: nosniff.
- Referrer-Policy header is missing: Define an appropriate Referrer-Policy header for this application.

PLANNED

Improve evidence quality and follow-up coverage.

- Cookie missing SameSite attribute: Set SameSite=Lax or SameSite=Strict unless cross-site usage is required.
- Review JavaScript-discovered endpoints before selecting later validation tests.
- Review OWASP WSTG/ASVS rule mappings before finalizing audit scope and report traceability.

COVERAGE NOTES

- http: warning - HTTP/HTTPS reachability and redirects checked.
- security_headers: warning - Security headers checked.
- cookies: warning - Checked 2 cookie(s).
- basic_auth: warning - HTTP authentication challenge checked.
- http_methods: warning - HTTP methods advertised by OPTIONS checked.
- ports: warning - Checked 3 TCP port(s), found 1 open port(s).
- fingerprinting: warning - Identified 4 technology signal(s) and checked 4 public metadata path(s).
- crawler: warning - Crawled 6 page(s), discovered 10 in-scope URL(s), 10 from metadata.
- HTML forms were identified passively; no form submission was performed.
- Entry points were derived from passive evidence: URLs, query strings, forms and advertised HTTP methods.
- State-changing entry points were inferred from methods or form actions; no request bodies were sent.
- Some entry point parameters have sensitive-looking names and should be reviewed without exposing their values.
- JavaScript endpoint references were extracted passively; discovered endpoints were not requested by this module.
- Passive rules mapped scan evidence to OWASP WSTG/ASVS references for audit traceability.
- Open TCP ports were detected using TCP connect checks only; no payloads or banners were requested.

SAFETY NOTES

- This assessment is generated from existing non-intrusive scan evidence only.
- No exploitation, brute force, fuzzing or destructive validation was performed.
- Risk should be reviewed against the authorized scope and business context.

VISUAL EVIDENCE

Estas capturas son visuales SVG generados localmente a partir del JSON de auditoria. No son screenshots de navegador ni ejecutan acciones adicionales contra el objetivo.

Metric	Value
Visual snapshots	3
Risk level	HIGH
Risk score	89/100
Technologies	4
URLs	36
Entry points	36
Module groups	4

GENERATED VISUALS

File	Description
visuals/audit-overview.svg	Resumen visual del objetivo, severidades, riesgo y cobertura principal de la auditoria.
visuals/fingerprint-map.svg	Mapa visual de tecnologias, metadatos publicos y superficie descubierta de forma pasiva.
visuals/coverage-matrix.svg	Matriz visual de modulos agrupados por fase para comprobar cobertura y estados.

FINGERPRINT HIGHLIGHTS

AIWebAuditorLab/0.25, Django, PHP 5.6.40, WordPress 4.7.0

VISUAL EVIDENCE SAFETY NOTES

- Visual snapshots are generated locally from passive scan evidence.
- No browser rendering, exploitation, brute force, fuzzing or form submission is performed to create these visuals.
- Sensitive values already redacted in the scan JSON remain redacted in visual evidence.

PASSIVE RULE MAPPING

Metric Value

Rules matched 13

Rules total 15

Findings mapped 21

Findings unmapped 0

OWASP controls matched 34

MATCHED RULES

Severity Rule Evidence Frameworks Next review

HIGH RULE-TRANSPORT-ENFORCE-TLS: Transport encryption and HTTPS enforcement findings: AUTH-BASIC-OVER-HTTP, HTTP-NO-HTTPS-REDIRECT OWASP WSTG WSTG-CRYP-03, OWASP WSTG WSTG-ATHN-01, OWASP ASVS 5.0 V12.2.1, OWASP ASVS 5.0 V14.2.1 Confirm HTTPS is enforced for every entry point and that HTTP redirects safely before authentication or session exchange.

MEDIUM RULE-SESSION-COOKIE-ATTRIBUTES: Cookie security attributes findings: COOKIE-HTTPONLY-MISSING, COOKIE-SAMESITE-MISSING, COOKIE-SAMESITE-NONE-WITHOUT-SECURE OWASP WSTG WSTG-SESS-02, OWASP ASVS 5.0 V3.3.1, OWASP ASVS 5.0 V3.3.2, OWASP ASVS 5.0 V3.3.4 Confirm session cookies use Secure, HttpOnly and a deliberate SameSite value based on the application flow.

MEDIUM RULE-FRONTEND-BROWSER-SECURITY-HEADERS: Browser security mechanism headers findings: HEADER-CLICKJACKING-MISSING, HEADER-CONTENT_SECURITY_POLICY-MISSING, HEADER-NOSNIFF-MISSING, HEADER-PERMISSIONS_POLICY-MISSING, HEADER-REFERRER_POLICY-MISSING OWASP WSTG WSTG-CONF-12, OWASP WSTG WSTG-CLNT-09, OWASP WSTG WSTG-CONF-14, OWASP ASVS 5.0 V3.4 Review CSP, frame-ancestors/X-Frame-Options, X-Content-Type-Options, Referrer-Policy and Permissions-Policy per route.

HIGH RULE-CONFIG-HTTP-METHODS: Advertised HTTP methods findings: METHOD-DELETE-ADVERTISED, METHOD-PUT-ADVERTISED, METHOD-TRACE-ADVERTISED OWASP WSTG WSTG-CONF-06, OWASP ASVS 5.0 V4.1.4, OWASP ASVS 5.0 V13.4.4 Verify that each advertised method is intentionally supported and protected by route-level authorization.

INFO RULE-INFO-TECH-FINGERPRINTING: Technology and version disclosure findings: FINGERPRINT-GENERATOR-DISCLOSED, FINGERPRINT-POWERED-BY-DISCLOSED, FINGERPRINT-SERVER-VERSION-DISCLOSED; signals: technologies_identified OWASP WSTG WSTG-INFO-02, OWASP WSTG WSTG-INFO-08, OWASP WSTG WSTG-INFO-10, OWASP ASVS 5.0 V13.4 Keep useful technology evidence, then remove precise version disclosure where it is not operationally required.

INFO RULE-INFO-WEBSERVER-METAFILES: Public metadata files and declared paths signals: public_metadata OWASP WSTG WSTG-INFO-03, OWASP WSTG WSTG-INFO-07, OWASP ASVS 5.0 V13.4 Review discovered metadata paths manually and decide what belongs in scope before following sensitive paths.

INFO RULE-INFO-ENTRY-POINTS: Application entry point inventory signals: entry_points_present, sensitive_parameters, state_changing_entry_points OWASP WSTG WSTG-INFO-06, OWASP WSTG WSTG-INFO-07, OWASP ASVS 5.0 V4.1.2 Prioritize state-changing endpoints, sensitive parameters and authenticated flows for later authorized testing.

INFO RULE-INFO-JAVASCRIPT-SURFACE: Client-side JavaScript exposed routes findings: JS-ENDPOINTS-DISCOVERED, JS-OUT-OF-SCOPE-ENDPOINTS, JS-SENSITIVE-PARAMETER-NAMES; signals: javascript_endpoints OWASP WSTG WSTG-INFO-05, OWASP WSTG WSTG-INFO-06, OWASP ASVS 5.0 V13.4 Review JavaScript-discovered endpoints before selecting any later validation or attack simulation.

INFO RULE-AUTH-AUTHENTICATION-SURFACE: Authentication and account-management surface signals: auth_routes OWASP WSTG WSTG-ATHN-01, OWASP WSTG WSTG-ATHN-09, OWASP ASVS 5.0 V6.1.3, OWASP ASVS 5.0 V6.4.3 Document every authentication path, recovery path and callback before testing controls in a later authorized phase.

INFO RULE-AUTHZ-ADMIN-SURFACE: Administrative and privileged route inventory signals: admin_routes OWASP WSTG WSTG-CONF-05, OWASP ASVS 5.0 V8.4.2 Confirm ownership, required roles and whether the route should remain in scope before any access-control testing.

INFO RULE-FILE-UPLOAD-SURFACE: File upload route inventory signals: upload_routes OWASP ASVS 5.0 V5.2.1, OWASP ASVS 5.0 V5.2.2 Confirm accepted file types, size limits, storage location and authorization before any upload testing.

INFO RULE-INFRA-DISCOVERY-SURFACE: Infrastructure surface from DNS and TCP checks findings: PORTS-OPEN-TCP-PORTS; signals: ports_open OWASP WSTG WSTG-INFO-04, OWASP WSTG WSTG-INFO-10, OWASP ASVS 5.0 V13.1.1 Confirm every resolved host and open port with the application owner before expanding testing beyond the main URL.

INFO RULE-SCOPE-EXTERNAL-REFERENCES: External and out-of-scope references findings: CRAWLER-OUT-OF-SCOPE-LINKS, JS-OUT-OF-SCOPE-ENDPOINTS; signals: external_references OWASP WSTG WSTG-INFO-10, OWASP ASVS 5.0 V13.2.4 Classify each external host as third-party, dependency, redirect target or candidate scope extension.

OWASP TRACEABILITY

Framework Control Severity Rules Evidence

OWASP ASVS 5.0 V12.2.1: TLS is used for client connectivity HIGH RULE-TRANSPORT-ENFORCE-TLS AUTH-BASIC-OVER-HTTP, HTTP-NO-HTTPS-REDIRECT

OWASP ASVS 5.0 V13.1.1: Application communication needs are documented INFO RULE-INFRA-DISCOVERY-SURFACE PORTS-OPEN-TCP-PORTS

OWASP ASVS 5.0 V13.2.4: External resource allowlists are defined INFO RULE-SCOPE-EXTERNAL-REFERENCES CRAWLER-OUT-OF-SCOPE-LINKS, JS-OUT-OF-SCOPE-ENDPOINTS

OWASP ASVS 5.0 V13.4: Unintended information leakage INFO RULE-INFO-JAVASCRIPT-SURFACE, RULE-INFO-TECH-FINGERPRINTING, RULE-INFO-WEBSERVER-METAFILES FINGERPRINT-GENERATOR-DISCLOSED, FINGERPRINT-POWERED-BY-DISCLOSED, FINGERPRINT-SERVER-VERSION-DISCLOSED, JS-ENDPOINTS-DISCOVERED, JS-OUT-OF-SCOPE-ENDPOINTS, JS-SENSITIVE-PARAMETER-NAMES

OWASP ASVS 5.0 V13.4.4: HTTP TRACE method is not supported in production HIGH RULE-CONFIG-HTTP-METHODS METHOD-DELETE-ADVERTISED, METHOD-PUT-ADVERTISED, METHOD-TRACE-ADVERTISED

OWASP ASVS 5.0 V14.2.1: Sensitive data is sent through protected channels HIGH RULE-TRANSPORT-ENFORCE-TLS AUTH-BASIC-OVER-HTTP, HTTP-NO-HTTPS-REDIRECT

OWASP ASVS 5.0 V3.3.1: Cookies have Secure attributes MEDIUM RULE-SESSION-COOKIE-ATTRIBUTES COOKIE-HTTPONLY-MISSING, COOKIE-SAMESITE-MISSING, COOKIE-SAMESITE-NONE-WITHOUT-SECURE

OWASP ASVS 5.0 V3.3.2: Cookies define a SameSite policy MEDIUM RULE-SESSION-COOKIE-ATTRIBUTES COOKIE-HTTPONLY-MISSING, COOKIE-SAMESITE-MISSING, COOKIE-SAMESITE-NONE-WITHOUT-SECURE

OWASP ASVS 5.0 V3.3.4: Sensitive cookies use HttpOnly MEDIUM RULE-SESSION-COOKIE-ATTRIBUTES COOKIE-HTTPONLY-MISSING, COOKIE-SAMESITE-MISSING, COOKIE-SAMESITE-NONE-WITHOUT-SECURE

OWASP ASVS 5.0 V3.4: Browser security mechanism headers MEDIUM RULE-FRONTEND-BROWSER-SECURITY-HEADERS HEADER-CLICKJACKING-MISSING, HEADER-CONTENT_SECURITY_POLICY-MISSING, HEADER-NOSNIFF-MISSING, HEADER-PERMISSIONS_POLICY-MISSING, HEADER-REFERRER_POLICY-MISSING

OWASP ASVS 5.0 V4.1.2: Only intended user-facing endpoints are exposed INFO RULE-INFO-ENTRY-POINTS signals: entry_points_present, sensitive_parameters, state_changing_entry_points

OWASP ASVS 5.0 V4.1.4: Only explicitly supported HTTP methods are accepted HIGH RULE-CONFIG-HTTP-METHODS METHOD-DELETE-ADVERTISED, METHOD-PUT-ADVERTISED, METHOD-TRACE-ADVERTISED

OWASP ASVS 5.0 V5.2.1: Accepted files have safe size limits INFO RULE-FILE-UPLOAD-SURFACE signals: upload_routes

OWASP ASVS 5.0 V5.2.2: Uploaded file extension and content are validated INFO RULE-FILE-UPLOAD-SURFACE signals: upload_routes

OWASP ASVS 5.0 V6.1.3: Multiple authentication pathways are documented INFO RULE-AUTH-AUTHENTICATION-SURFACE signals: auth_routes

OWASP ASVS 5.0 V6.4.3: Secure forgotten password reset process INFO RULE-AUTH-AUTHENTICATION-SURFACE signals: auth_routes

OWASP ASVS 5.0 V8.4.2: Administrative interfaces include stronger access controls INFO RULE-AUTHZ-ADMIN-SURFACE signals: admin_routes

OWASP WSTG WSTG-ATHN-01: Credentials transported over an encrypted channel HIGH RULE-AUTH-AUTHENTICATION-SURFACE, RULE-TRANSPORT-ENFORCE-TLS AUTH-BASIC-OVER-HTTP, HTTP-NO-HTTPS-REDIRECT

OWASP WSTG WSTG-ATHN-09: Weak password change or reset functionality INFO RULE-AUTH-AUTHENTICATION-SURFACE signals: auth_routes

OWASP WSTG WSTG-CLNT-09: Clickjacking MEDIUM RULE-FRONTEND-BROWSER-SECURITY-HEADERS HEADER-CLICKJACKING-MISSING, HEADER-CONTENT_SECURITY_POLICY-MISSING, HEADER-NOSNIFF-MISSING, HEADER-PERMISSIONS_POLICY-MISSING, HEADER-REFERRER_POLICY-MISSING

OWASP WSTG WSTG-CONF-05: Enumerate infrastructure and application admin interfaces INFO RULE-AUTHZ-ADMIN-SURFACE signals: admin_routes

OWASP WSTG WSTG-CONF-06: HTTP methods HIGH RULE-CONFIG-HTTP-METHODS METHOD-DELETE-ADVERTISED, METHOD-PUT-ADVERTISED, METHOD-TRACE-ADVERTISED

OWASP WSTG WSTG-CONF-12: Content Security Policy MEDIUM RULE-FRONTEND-BROWSER-SECURITY-HEADERS HEADER-CLICKJACKING-MISSING, HEADER-CONTENT_SECURITY_POLICY-MISSING, HEADER-NOSNIFF-MISSING, HEADER-PERMISSIONS_POLICY-MISSING, HEADER-REFERRER_POLICY-MISSING

OWASP WSTG WSTG-CONF-14: Other HTTP security header misconfigurations MEDIUM RULE-FRONTEND-BROWSER-SECURITY-HEADERS HEADER-CLICKJACKING-MISSING, HEADER-CONTENT_SECURITY_POLICY-MISSING, HEADER-NOSNIFF-MISSING, HEADER-PERMISSIONS_POLICY-MISSING, HEADER-REFERRER_POLICY-MISSING

OWASP WSTG WSTG-CRYP-03: Sensitive information sent via unencrypted channels HIGH RULE-TRANSPORT-ENFORCE-TLS AUTH-BASIC-OVER-HTTP, HTTP-NO-HTTPS-REDIRECT

OWASP WSTG WSTG-INFO-02: Fingerprint web server INFO RULE-INFO-TECH-FINGERPRINTING FINGERPRINT-GENERATOR-DISCLOSED, FINGERPRINT-POWERED-BY-DISCLOSED, FINGERPRINT-SERVER-VERSION-DISCLOSED

OWASP WSTG WSTG-INFO-03: Review webserver metafiles for information leakage INFO RULE-INFO-WEBSERVER-METAFILES signals: public_metadata

OWASP WSTG WSTG-INFO-04: Enumerate applications on webserver INFO RULE-INFRA-DISCOVERY-SURFACE PORTS-OPEN-TCP-PORTS

OWASP WSTG WSTG-INFO-05: Review web page content for information leakage INFO RULE-INFO-JAVASCRIPT-SURFACE JS-ENDPOINTS-DISCOVERED, JS-OUT-OF-SCOPE-ENDPOINTS, JS-SENSITIVE-

PARAMETER-NAMES

OWASP WSTG WSTG-INFO-06: Identify application entry points INFO RULE-INFO-ENTRY-POINTS, RULE-INFO-JAVASCRIPT-SURFACE JS-ENDPOINTS-DISCOVERED, JS-OUT-OF-SCOPE-ENDPOINTS, JS-SENSITIVE-PARAMETER-NAMES

OWASP WSTG WSTG-INFO-07: Map execution paths through application INFO RULE-INFO-ENTRY-POINTS, RULE-INFO-WEBSERVER-METAFILES signals: entry_points_present, public_metadata, sensitive_parameters, state_changing_entry_points

OWASP WSTG WSTG-INFO-08: Fingerprint web application framework INFO RULE-INFO-TECH-FINGERPRINTING FINGERPRINT-GENERATOR-DISCLOSED, FINGERPRINT-POWERED-BY-DISCLOSED, FINGERPRINT-SERVER-VERSION-DISCLOSED

OWASP WSTG WSTG-INFO-10: Map application architecture INFO RULE-INFO-TECH-FINGERPRINTING, RULE-INFRA-DISCOVERY-SURFACE, RULE-SCOPE-EXTERNAL-REFERENCES CRAWLER-OUT-OF-SCOPE-LINKS, FINGERPRINT-GENERATOR-DISCLOSED, FINGERPRINT-POWERED-BY-DISCLOSED, FINGERPRINT-SERVER-VERSION-DISCLOSED, JS-OUT-OF-SCOPE-ENDPOINTS, PORTS-OPEN-TCP-PORTS

OWASP WSTG WSTG-SESS-02: Cookie attributes MEDIUM RULE-SESSION-COOKIE-ATTRIBUTES COOKIE-HTTPONLY-MISSING, COOKIE-SAMESITE-MISSING, COOKIE-SAMESITE-NONE-WITHOUT-SECURE

RULE SAFETY NOTES

- Rules are evaluated from existing passive scan evidence only.
- A matched rule is review guidance, not proof of exploitability.
- Out-of-scope references are recorded but must not be scanned without explicit authorization.

MODULE SUMMARY

Module Status Summary

scope passed Target URL validated and inside configured scope.

http warning HTTP/HTTPS reachability and redirects checked.

security_headers warning Security headers checked.

cookies warning Checked 2 cookie(s).

basic_auth warning HTTP authentication challenge checked.

http_methods warning HTTP methods advertised by OPTIONS checked.

ports warning Checked 3 TCP port(s), found 1 open port(s).

fingerprinting warning Identified 4 technology signal(s) and checked 4 public metadata path(s).

crawler warning Crawled 6 page(s), discovered 10 in-scope URL(s), 10 from metadata.

javascript passed Analyzed 6 page(s) and 3 script block(s), discovered 9 in-scope endpoint reference(s).

FINDINGS

HIGH - HTTP BASIC AUTHENTICATION OVER HTTP

- ID: AUTH-BASIC-OVER-HTTP
- Category: authentication
- Module: basic_auth
- Target: http://127.0.0.1:55917/members/

Description

The server requests Basic Authentication over unencrypted HTTP.

Recommendation

Force HTTPS before authentication and enable HSTS after validation.

Evidence

- status_code: 401
- www-authenticate: Basic realm="AI Web Auditor Lab"

HIGH - HTTP IS NOT REDIRECTED TO HTTPS

- ID: HTTP-NO-HTTPS-REDIRECT
- Category: transport-security
- Module: http
- Target: http://127.0.0.1:55917/members/

Description

The requested HTTP URL remains available without being upgraded to HTTPS.

Recommendation

Redirect all HTTP traffic to HTTPS and consider enabling HSTS after verification.

Evidence

- initial_url: http://127.0.0.1:55917/members/
- final_url: http://127.0.0.1:55917/members/
- status_code: 401

HIGH - HTTP METHOD TRACE IS ADVERTISED

- ID: METHOD-TRACE-ADVERTISED
- Category: http-methods
- Module: http_methods
- Target: http://127.0.0.1:55917/members/

Description

TRACE can expose request data and is rarely needed.

Recommendation

Disable unnecessary HTTP methods or enforce strict authorization before use.

Evidence

- allow: GET, POST, OPTIONS, PUT, DELETE, TRACE
- access-control-allow-methods: GET, POST, OPTIONS, PUT, DELETE, TRACE

MEDIUM - COOKIE USES SAMESITE=NONE WITHOUT SECURE

- ID: COOKIE-SAMESITE-NONE-WITHOUT-SECURE
- Category: cookies
- Module: cookies
- Target: http://127.0.0.1:55917/members/

Description

SameSite=None cookies should also use Secure.

Recommendation

Set Secure or avoid SameSite=None if cross-site usage is not required.

Evidence

- cookie: tracking_id

MEDIUM - CONTENT-SECURITY-POLICY HEADER IS MISSING

- ID: HEADER-CONTENT_SECURITY_POLICY-MISSING
- Category: security-headers
- Module: security_headers
- Target: http://127.0.0.1:55917/members/

Description

The response does not include the Content-Security-Policy header.

Recommendation

Define an appropriate Content-Security-Policy header for this application.

MEDIUM - HTTP METHOD DELETE IS ADVERTISED

- ID: METHOD-DELETE-ADVERTISED
- Category: http-methods
- Module: http_methods
- Target: http://127.0.0.1:55917/members/

Description

DELETE may allow destructive actions if authorization is weak.

Recommendation

Disable unnecessary HTTP methods or enforce strict authorization before use.

Evidence

- allow: GET, POST, OPTIONS, PUT, DELETE, TRACE
- access-control-allow-methods: GET, POST, OPTIONS, PUT, DELETE, TRACE

MEDIUM - HTTP METHOD PUT IS ADVERTISED

- ID: METHOD-PUT-ADVERTISED
- Category: http-methods
- Module: http_methods
- Target: http://127.0.0.1:55917/members/

Description

PUT may allow content upload if authorization is weak.

Recommendation

Disable unnecessary HTTP methods or enforce strict authorization before use.

Evidence

- allow: GET, POST, OPTIONS, PUT, DELETE, TRACE
- access-control-allow-methods: GET, POST, OPTIONS, PUT, DELETE, TRACE

LOW - COOKIE MISSING HTTPONLY FLAG

- ID: COOKIE-HTTPONLY-MISSING
- Category: cookies
- Module: cookies
- Target: http://127.0.0.1:55917/members/

Description

A cookie is accessible to client-side scripts when HttpOnly is absent.

Recommendation

Set HttpOnly for session or sensitive cookies.

Evidence

- cookie: sessionid

LOW - COOKIE MISSING HTTPONLY FLAG

- ID: COOKIE-HTTPONLY-MISSING
- Category: cookies
- Module: cookies
- Target: http://127.0.0.1:55917/members/

Description

A cookie is accessible to client-side scripts when HttpOnly is absent.

Recommendation

Set HttpOnly for session or sensitive cookies.

Evidence

- cookie: tracking_id

LOW - COOKIE MISSING SAMESITE ATTRIBUTE

- ID: COOKIE-SAMESITE-MISSING
- Category: cookies
- Module: cookies
- Target: http://127.0.0.1:55917/members/

Description

A cookie does not declare a SameSite policy.

Recommendation

Set SameSite=Lax or SameSite=Strict unless cross-site usage is required.

Evidence

- cookie: sessionid

LOW - CLICKJACKING PROTECTION HEADER IS MISSING

- ID: HEADER-CLICKJACKING-MISSING
- Category: security-headers
- Module: security_headers
- Target: http://127.0.0.1:55917/members/

Description

The response does not include X-Frame-Options or a CSP frame-ancestors directive.

Recommendation

Set frame-ancestors in Content-Security-Policy or use X-Frame-Options where appropriate.

LOW - X-CONTENT-TYPE-OPTIONS NOSNIFF IS MISSING

- ID: HEADER-NOSNIFF-MISSING
- Category: security-headers
- Module: security_headers
- Target: http://127.0.0.1:55917/members/

Description

The browser may try to infer content types when nosniff is absent.

Recommendation

Set X-Content-Type-Options: nosniff.

Evidence

- x-content-type-options: missing

LOW - REFERRER-POLICY HEADER IS MISSING

- ID: HEADER-REFERRER_POLICY-MISSING
- Category: security-headers
- Module: security_headers
- Target: http://127.0.0.1:55917/members/

Description

The response does not include the Referrer-Policy header.

Recommendation

Define an appropriate Referrer-Policy header for this application.

INFO - CRAWLER FOUND LINKS OUTSIDE SCOPE

- ID: CRAWLER-OUT-OF-SCOPE-LINKS
- Category: crawler
- Module: crawler
- Target: http://127.0.0.1:55917/members/

Description

The crawler discovered links outside the configured scope. They were recorded but not requested.

Recommendation

Review whether any external host should be added to the authorized scope before scanning it.

Evidence

- sample_url: https://example.org/external

INFO - HTML GENERATOR METADATA IS EXPOSED

- ID: FINGERPRINT-GENERATOR-DISCLOSED
- Category: fingerprinting
- Module: fingerprinting
- Target: http://127.0.0.1:55917/members/

Description

The HTML generator metadata can disclose CMS or framework details.

Recommendation

Remove generator metadata if it is not required.

Evidence

- generator: WordPress 4.7.0

INFO - X-POWERED-BY HEADER DISCLOSES TECHNOLOGY INFORMATION

- ID: FINGERPRINT-POWERED-BY-DISCLOSED

- Category: fingerprinting

- Module: fingerprinting

- Target: <http://127.0.0.1:55917/members/>

Description

The X-Powered-By header can reveal backend technology details to attackers.

Recommendation

Remove or reduce technology-identifying response headers where practical.

Evidence

- x-powered-by: PHP/5.6.40

INFO - SERVER HEADER DISCLOSES VERSION INFORMATION

- ID: FINGERPRINT-SERVER-VERSION-DISCLOSED

- Category: fingerprinting

- Module: fingerprinting

- Target: <http://127.0.0.1:55917/members/>

Description

The Server header appears to include product version information.

Recommendation

Avoid exposing precise server versions unless there is an operational reason.

Evidence

- server: AIWebAuditorLab/0.25

INFO - PERMISSIONS-POLICY HEADER IS MISSING

- ID: HEADER-PERMISSIONS_POLICY-MISSING

- Category: security-headers

- Module: security_headers
- Target: http://127.0.0.1:55917/members/

Description

The response does not include the Permissions-Policy header.

Recommendation

Define an appropriate Permissions-Policy header for this application.

INFO - JAVASCRIPT ENDPOINT REFERENCES DISCOVERED

- ID: JS-ENDPOINTS-DISCOVERED
- Category: javascript-enumeration
- Module: javascript
- Target: http://127.0.0.1:55917/members/

Description

Client-side JavaScript contains URL references that expand the passive review surface.

Recommendation

Review these endpoints against the authorized scope before deciding whether later validation is needed.

Evidence

- endpoint: http://127.0.0.1:55917/api
- endpoint: POST http://127.0.0.1:55917/api/member-profile?csrf_token=[redacted]
- endpoint: POST http://127.0.0.1:55917/api/profile?session_id=[redacted]
- endpoint: POST http://127.0.0.1:55917/api/upload
- endpoint: GET http://127.0.0.1:55917/api/users?role=member

INFO - JAVASCRIPT REFERENCES ENDPOINTS OUTSIDE SCOPE

- ID: JS-OUT-OF-SCOPE-ENDPOINTS
- Category: javascript-enumeration
- Module: javascript
- Target: http://127.0.0.1:55917/members/

Description

Client-side JavaScript references hosts outside the configured scope. They were recorded but not requested.

Recommendation

Confirm whether those hosts belong to the engagement before scanning them.

Evidence

- endpoint: <https://example.org/collect>

INFO - JAVASCRIPT REFERENCES SENSITIVE-LOOKING PARAMETER NAMES

- ID: JS-SENSITIVE-PARAMETER-NAMES
- Category: javascript-enumeration
- Module: javascript
- Target: <http://127.0.0.1:55917/members/>

Description

Some JavaScript-discovered URLs contain parameter names commonly associated with authentication, sessions or secrets. Values are redacted.

Recommendation

Review how these parameters are generated, logged and exposed. Do not include raw secrets in reports.

Evidence

- parameter_name ([http://127.0.0.1:55917/api/member-profile?csrf_token=\[redacted\]](http://127.0.0.1:55917/api/member-profile?csrf_token=[redacted])): csrf_token
- parameter_name ([http://127.0.0.1:55917/api/profile?session_id=\[redacted\]](http://127.0.0.1:55917/api/profile?session_id=[redacted])): session_id
- parameter_name ([http://127.0.0.1:55917/reset-password?token=\[redacted\]](http://127.0.0.1:55917/reset-password?token=[redacted])): token

INFO - OPEN TCP PORTS DETECTED

- ID: PORTS-OPEN-TCP-PORTS
- Category: network-exposure
- Module: ports
- Target: 127.0.0.1

Description

The limited TCP connectivity check found open ports on the target host. This is inventory evidence, not exploitation.

Recommendation

Review whether each exposed service is expected, patched and covered by the authorized audit scope.

Evidence

- open_port: 55917

TECHNOLOGY FINGERPRINTING

Technology Category Confidence Signals
AIWebAuditorLab/0.25 server low header:server

Django framework medium cookie:sessionid
PHP 5.6.40 language high header:x-powered-by
WordPress 4.7.0 cms high html:meta-generator

PUBLIC METADATA FILES

Path	Status	Present
/robots.txt	200	True
/.well-known/security.txt	200	True
/security.txt	404	False
/sitemap.xml	200	True

CRAWLER

- Seed URL: http://127.0.0.1:55917/members/
- Max depth: 1
- Max pages: 20
- Fetched URLs: 6
- Discovered in-scope URLs: 10
- Metadata-discovered URLs: 10
- Classified interesting routes: 7
- robots.txt: present (200)
- Sitemaps checked: 1 (1 present)
- .well-known endpoints checked: 8 (2 present)
- Out-of-scope URLs recorded but not visited: 1
- Excluded URLs recorded but not visited: 3

INTERESTING ROUTES

URL	Types	Sources
http://127.0.0.1:55917/account	account	crawler_fetched, sitemap
http://127.0.0.1:55917/api/users	api	crawler_fetched, sitemap
http://127.0.0.1:55917/login	form, login	crawler_fetched, sitemap
http://127.0.0.1:55917/members/	account, form, login	crawler_fetched, html_link, robots_allow, seed, sitemap
http://127.0.0.1:55917/oauth/authorize	callback, login	well_known_endpoint
http://127.0.0.1:55917/oauth/token	callback	well_known_endpoint
http://127.0.0.1:55917/reset-password	password_reset	crawler_fetched, sitemap

PRESENT .WELL-KNOWN ENDPOINTS

Path	Status	Highlights
/.well-known/security.txt	200	contact: mailto:security@example.test; policy: http://127.0.0.1/security-policy
/.well-known/openid-configuration	200	endpoints: 2

DISCOVERED URLS

- http://127.0.0.1:55917/
- http://127.0.0.1:55917/.well-known/openid-configuration
- http://127.0.0.1:55917/.well-known/security.txt
- http://127.0.0.1:55917/account

- http://127.0.0.1:55917/api/users
- http://127.0.0.1:55917/login
- http://127.0.0.1:55917/members/
- http://127.0.0.1:55917/oauth/authorize
- http://127.0.0.1:55917/oauth/token
- http://127.0.0.1:55917/reset-password

OUT-OF-SCOPE URLS

- https://example.org/external

EXCLUDED URLS

- http://127.0.0.1:55917/admin/
- http://127.0.0.1:55917/private/
- http://127.0.0.1:55917/private/report

JAVASCRIPT ANALYSIS

- Pages checked: 6
- Script blocks analyzed: 3
- In-scope endpoint references: 9
- Sensitive-looking parameter names: 3
- Out-of-scope endpoint references recorded but not requested: 1
- Excluded endpoint references recorded but not requested: 1

Only HTML and JavaScript resources inside the configured scope were requested. Discovered endpoints were not executed.

JAVASCRIPT ENDPOINT REFERENCES

URL Method Parameters Route types Sources

```
http://127.0.0.1:55917/api unknown unknown api external_script
http://127.0.0.1:55917/api/member-profile?csrf_token=%5Bredacted%5D POST csrf_token
account, api, state_changing_candidate inline_script
http://127.0.0.1:55917/api/profile?session_id=%5Bredacted%5D POST session_id account,
api, state_changing_candidate external_script, inline_script
http://127.0.0.1:55917/api/upload POST unknown api, state_changing_candidate, upload
external_script
http://127.0.0.1:55917/api/users?role=member GET role api external_script
http://127.0.0.1:55917/callback/oauth unknown unknown callback external_script
http://127.0.0.1:55917/health unknown unknown health inline_script
http://127.0.0.1:55917/oauth/authorize?client_id=demo unknown client_id callback, login
external_script
http://127.0.0.1:55917/reset-password?token=%5Bredacted%5D unknown token password_reset
inline_script
```

SCRIPTS ANALYZED

Kind URL/Page Status Type Endpoints

```
external http://127.0.0.1:55917/static/app.js 200 application/javascript; charset=utf-8
```

inline http://127.0.0.1:55917/members/ unknown unknown 2
inline http://127.0.0.1:55917/ unknown unknown 1

OUT-OF-SCOPE JAVASCRIPT REFERENCES

- https://example.org/collect

EXCLUDED JAVASCRIPT REFERENCES

- http://127.0.0.1:55917/admin/export?token=%5Bredacted%5D

WEB INVENTORY

- Total URLs: 36
- Fetched URLs: 17
- Interesting URLs: 24
- Forms detected: 2
- Out-of-scope URLs recorded but not visited: 2
- Excluded URLs recorded but not visited: 4

URL INVENTORY

URL Status Type Forms Interest

http://127.0.0.1:55917/.well-known/change-password 404 unknown 0 password_reset,
password_reset_path
http://127.0.0.1:55917/.well-known/oauth-authorization-server 404 unknown 0 callback,
callback_path
http://127.0.0.1:55917/account 403 text/html; charset=utf-8 0 account, account_area
http://127.0.0.1:55917/admin/ unknown unknown 0 admin, admin_path
http://127.0.0.1:55917/admin/export?token=%5Bredacted%5D unknown unknown 0 admin,
admin_path
http://127.0.0.1:55917/api unknown unknown 0 api, api_path
http://127.0.0.1:55917/api/member-profile?csrf_token=%5Bredacted%5D unknown unknown 0
account, api, state_changing_candidate, account_area, api_path, post_method
http://127.0.0.1:55917/api/profile?session_id=%5Bredacted%5D unknown unknown 0 account,
api, state_changing_candidate, account_area, api_path, post_method
http://127.0.0.1:55917/api/upload unknown unknown 0 api, state_changing_candidate,
upload, api_path, upload_path, post_method
http://127.0.0.1:55917/api/users 200 application/json; charset=utf-8 0 api, api_path
http://127.0.0.1:55917/api/users?role=member unknown unknown 0 api, api_path
http://127.0.0.1:55917/callback/oauth unknown unknown 0 callback, callback_path
http://127.0.0.1:55917/health unknown unknown 0 health, health_status_path
http://127.0.0.1:55917/login 200 text/html; charset=utf-8 1 form, login, login_path,
form_detected
http://127.0.0.1:55917/login/ unknown unknown 0 login, state_changing_candidate,
login_path, post_method
http://127.0.0.1:55917/members/ 401 text/html; charset=utf-8 1 account, form, login,
login_path, account_area, form_detected
http://127.0.0.1:55917/oauth/authorize unknown unknown 0 callback, login, login_path,
callback_path
http://127.0.0.1:55917/oauth/authorize?client_id=demo unknown unknown 0 callback, login,
login_path, callback_path

<http://127.0.0.1:55917/oauth/token> unknown unknown 0 callback, callback_path
<http://127.0.0.1:55917/private/> unknown unknown 0 account, account_area
<http://127.0.0.1:55917/private/report> unknown unknown 0 account, account_area
<http://127.0.0.1:55917/reset-password> 200 text/html; charset=utf-8 0 password_reset, password_reset_path
<http://127.0.0.1:55917/reset-password?token=%5Bredacted%5D> unknown unknown 0 password_reset, password_reset_path
<http://127.0.0.1:55917/session> unknown unknown 0 login, state_changing_candidate, login_path, post_method
<http://127.0.0.1:55917/> 200 text/html; charset=utf-8 0 unknown
<http://127.0.0.1:55917/.well-known/openid-configuration> 200 unknown 0 unknown
<http://127.0.0.1:55917/.well-known/security.txt> 200 unknown 0 unknown
<https://example.org/collect> unknown unknown 0 unknown
<https://example.org/external> unknown unknown 0 unknown
<http://127.0.0.1:55917/.well-known/apple-app-site-association> 404 unknown 0 unknown
<http://127.0.0.1:55917/.well-known/assetlinks.json> 404 unknown 0 unknown
<http://127.0.0.1:55917/.well-known/webfinger> 404 unknown 0 unknown
<http://127.0.0.1:55917/robots.txt> 200 unknown 0 unknown
<http://127.0.0.1:55917/security.txt> 404 unknown 0 unknown
<http://127.0.0.1:55917/sitemap.xml> 200 unknown 0 unknown
<http://127.0.0.1:55917/static/app.js> 200 application/javascript; charset=utf-8 0 static_asset

FORMS

Page Action Method Inputs Password Fields

<http://127.0.0.1:55917/login> <http://127.0.0.1:55917/session> POST 2 1
<http://127.0.0.1:55917/members/> <http://127.0.0.1:55917/login/> POST 3 1

ENTRY POINTS

- Endpoints: 36
- Review candidates: 29
- Forms: 2
- Parameters: 8
- State-changing endpoints: 6

Only passive evidence was used: URLs, query strings, forms and advertised HTTP methods. No form submission was performed.

HTTP METHODS OBSERVED

Method Endpoints State-changing

DELETE 1 True
 GET 18 False
 OPTIONS 1 False
 POST 6 True
 PUT 1 True
 TRACE 1 False

ENDPOINT REVIEW LIST

URL State Methods Parameters Forms Route types Notes

http://127.0.0.1:55917/login/ form_action POST csrf_token, password, username 1 login, state_changing_candidate form_action, login_route, parameters_observed, sensitive_parameter_name, state_changing_method

http://127.0.0.1:55917/session form_action POST password, user 1 login, state_changing_candidate form_action, login_route, parameters_observed, sensitive_parameter_name, state_changing_method

http://127.0.0.1:55917/api/member-profile?csrf_token=%5Bredacted%5D discovered POST csrf_token 0 account, api, state_changing_candidate api_route, parameters_observed, sensitive_parameter_name, state_changing_method

http://127.0.0.1:55917/api/profile?session_id=%5Bredacted%5D discovered POST session_id 0 account, api, state_changing_candidate api_route, parameters_observed, sensitive_parameter_name, state_changing_method

http://127.0.0.1:55917/api/upload discovered POST unknown 0 api, state_changing_candidate, upload api_route, state_changing_method, upload_route

http://127.0.0.1:55917/members/ fetched DELETE, GET, OPTIONS, POST, PUT, TRACE unknown 0 account, form, login login_route, state_changing_method

http://127.0.0.1:55917/api/users?role=member discovered GET role 0 api api_route, parameters_observed

http://127.0.0.1:55917/oauth/authorize?client_id=demo discovered unknown client_id 0 callback, login callback_route, login_route, parameters_observed

http://127.0.0.1:55917/reset-password?token=%5Bredacted%5D discovered unknown token 0 password_reset parameters_observed, password_reset_route, sensitive_parameter_name

http://127.0.0.1:55917/ fetched GET unknown 0 unknown unknown

http://127.0.0.1:55917/.well-known/apple-app-site-association fetched GET unknown 0 unknown unknown

http://127.0.0.1:55917/.well-known/assetlinks.json fetched GET unknown 0 unknown unknown

http://127.0.0.1:55917/.well-known/change-password fetched GET unknown 0 password_reset password_reset_route

http://127.0.0.1:55917/.well-known/oauth-authorization-server fetched GET unknown 0 callback callback_route

http://127.0.0.1:55917/.well-known/openid-configuration fetched GET unknown 0 unknown unknown

http://127.0.0.1:55917/.well-known/security.txt fetched GET unknown 0 unknown unknown

http://127.0.0.1:55917/.well-known/webfinger fetched GET unknown 0 unknown unknown

http://127.0.0.1:55917/account fetched GET unknown 0 account unknown

http://127.0.0.1:55917/api discovered unknown unknown 0 api api_route

http://127.0.0.1:55917/api/users fetched GET unknown 0 api api_route

http://127.0.0.1:55917/callback/oauth discovered unknown unknown 0 callback callback_route

http://127.0.0.1:55917/health discovered unknown unknown 0 health unknown

http://127.0.0.1:55917/login fetched GET unknown 0 form, login login_route

http://127.0.0.1:55917/oauth/authorize metadata unknown unknown 0 callback, login callback_route, login_route

http://127.0.0.1:55917/oauth/token metadata unknown unknown 0 callback callback_route

http://127.0.0.1:55917/reset-password fetched GET unknown 0 password_reset password_reset_route

http://127.0.0.1:55917/robots.txt fetched GET unknown 0 unknown unknown

http://127.0.0.1:55917/security.txt fetched GET unknown 0 unknown unknown

http://127.0.0.1:55917/sitemap.xml fetched GET unknown 0 unknown unknown

http://127.0.0.1:55917/admin/export?token=%5Bredacted%5D excluded unknown token 0 admin

	admin_route	parameters_observed	sensitive_parameter_name
http://127.0.0.1:55917/admin/	excluded	unknown	unknown 0 admin admin_route
http://127.0.0.1:55917/private/	excluded	unknown	unknown 0 account unknown
http://127.0.0.1:55917/private/report	excluded	unknown	unknown 0 account unknown
http://127.0.0.1:55917/static/app.js	fetches	GET	unknown 0 static_asset unknown
https://example.org/collect	out_of_scope	unknown	unknown 0 unknown unknown
https://example.org/external	out_of_scope	unknown	unknown 0 unknown unknown

FORM ENTRY POINTS

Page	Action	Method	Inputs	Password fields	CSRF candidates
http://127.0.0.1:55917/login	http://127.0.0.1:55917/session	POST	2	1	unknown
http://127.0.0.1:55917/members/	http://127.0.0.1:55917/login/	POST	3	1	csrf_token

SENSITIVE-LOOKING PARAMETERS

Parameter	Locations	Occurrences	Methods
csrf_token	form, query	2	POST
password	form	2	POST
session_id	query	1	unknown
token	query	2	unknown

TCP PORT CHECK

- Host: 127.0.0.1
- Ports checked: 3
- Open ports: 1
- Closed ports: 0
- Filtered ports: 2
- Only TCP connect checks were performed; no payloads or banners were requested.

Port	Service	Status	Elapsed
55917	unknown	open	0 ms
80	http	filtered	500 ms
443	https	filtered	516 ms

LIMITATIONS

- This report is based on non-intrusive checks only.
- No exploitation, brute force, aggressive fuzzing or destructive testing was performed.
- Findings should be validated against the authorized scope and business context.